BIL 481 Software Engineering - Project Assignment 1

Proje Adı: Yazılım Tedarik Zinciri Risk Tarayıcısı (yztr) / Software Supply Chain Risk Scanner

Grup Adı: CodeShield

3. Project Plan Document

Yazarlar (Authorship): Kaan Zor, Ramazan Emir Keleş, Nuh Yusuf Sabırer

İçindekiler (Table of Contents)

- Proje Kapsamı (Project Scope)
- Proje Organizasyonu (Project Organization - People)
- Proje Yönetimi Hedefleri (Objectives)
- Temel Aşamalar ve Zaman Çizelgesi (Key Phases and Timeline)
- Kaynak Planlaması (Resource Planning)
- Risk Yönetimi (Risk Management)
- İletişim Planı (Communication Plan)
- Değişiklik Yönetimi Planı (Change Management Plan)
- Bütçe Planı (Budget Plan)
- Efor Tahminleri (Effort Estimations)
- Görev Atamaları (Task Assignments)
- Dokümana Özel Görev Matrisi (Document-Specific Task Matrix)

3.1 Proje Kapsamı

Proje; npm, PyPI ve Maven paket yönetim sistemlerini destekleyen, Git PR farklarını hesaplayarak zafiyet, lisans çakışması ve "typosquatting" güvenlik kontrollerini yapan bir CLI aracı ve GitHub Action eklentisinin geliştirilmesini kapsar. Mevcut kodu düzeltme (auto-fix) veya bağımlılık silme eylemleri kapsam dışındadır.

3.2 Proje Organizasyonu (Roller ve Sorumluluklar)

- **Kaan Zor:** Scrum Master. Proje takibi, takım koordinasyonu ve dış bağımlılıkların (HTTP/Cache katmanı) geliştirilmesinden sorumlu.
- **Nuh Yusuf Sabırer:** Architect (Mimar). Temel veri yapıları (Dependency Graph), ekosistem ayrıştırıcıları (lockfile parser) ve sürüm sıralama algoritmalarından sorumlu.
- **Ömer Ali Sarıcalar:** Requirements Lead. Gereksinim analizi, lisans motoru (SPDX parser) ve uyumluluk denetimi kodlamasından sorumlu.
- **Yusuf Emir Coşar:** QA Lead. Sistem testleri, typosquatting tespit algoritması ve kayıt defteri (registry) doğrulamalarından sorumlu.
- **Ramazan Emir Keleş:** DevOps / Release. GitHub Action wrapper yazılımı, YAML politika motoru entegrasyonu, CI/CD süreçleri ve komut satırı (CLI) çıktı raporlamasından sorumlu.

3.3 Proje Yönetimi Hedefleri

Projenin 8 haftalık pencere içinde (12 Ekim 2026 - 11 Aralık 2026), belirlenen efor limitlerine (kişi başı haftalık ~15 saat) uyularak tamamlanması hedeflenmektedir. Her PR için otomatik testlerin çalıştırılması ve kod incelemelerinin onay (approval) alınmadan "main" dalına aktarılmaması amaçlanmaktadır.

3.4 Temel Aşamalar ve Zaman Çizelgesi

Proje süresi: 12 Ekim 2026 - 11 Aralık 2026

1. **Gereksinimler ve Tasarım Aşaması (12-25 Ekim):** Lockfile ayrıştırma modellerinin, GitHub Concept Note ve PA-1 teslimlerinin tamamlanması.
2. **Core Geliştirme Aşaması (26 Ekim - 15 Kasım):** Dependency Graph (yztr-parser), OSV entegrasyonu (yztr-vuln), lisans analizi (yztr-license) ve typosquatting algoritmalarının kodlanması.
3. **Entegrasyon ve GitHub Action Aşaması (16-29 Kasım):** CLI komutlarının (yztr-cli-action) tamamlanması, YAML Policy altyapısının birleştirilmesi ve GitHub PR yorum oluşturma işlevinin geliştirilmesi.
4. **Test ve Kalite Güvencesi Aşaması (30 Kasım - 6 Aralık):** JUnit 5 ve JaCoCo testleri, golden-file determinizm testleri ve performans/hız metriklerinin (NFR-1, NFR-2) doğrulanması.

5. **Proje Kapanışı ve Teslimi (7-11 Aralık):** Nihai rapor dokümantasyonu (PA-3) ve projenin değerlendirmeye sunulması.

3.5 Kaynak Planlaması

- **Yazılım/Araçlar:** Java 21 LTS, IDE (IntelliJ/Eclipse), Git & GitHub (sürüm kontrolü), Maven (Build Tool). Bağımlılıklar: picocli, Jackson, H2 Embedded DB, CycloneDX kütüphanesi.
- **Test Kütüphaneleri:** JUnit 5, jqwik, WireMock, JMH, JaCoCo.
- **Erişim:** İnternet erişimi, OSV.dev ve açık paket kayıt defteri API'leri.

3.6 Risk Yönetimi

- **Risk:** Herhangi bir takım üyesinin yoğunluk sebebiyle geride kalması.
    - **Önlem:** Görev atamaları modüler yapıya (yztr-core, yztr-parser, yztr-vuln vb.) göre yapılmış olup, kritik yollarda paralel çalışma desteklenecektir.
- **Risk:** Üçüncü parti bağımlılıklarda uyumsuzluk (SPDX çözümlemede zorluk).
    - **Önlem:** Temel algoritmalar hazır kütüphaneler yerine standartlaştırılmış Regex/JSON parsers üzerinden yönetilecek, riskli denemeler test branch'lerinde yapılacaktır.

3.7 İletişim Planı

- **Ekip İçi İletişim:** Haftalık çevrimiçi toplantılar, hızlı iletişim için WhatsApp/Discord.
- **Görev Takibi:** Tüm süreç GitHub Repository üzerinden (Issues, PR comments ve Commit mesajları kullanılarak) izlenecektir. Takım üyelerinin katkılarının şeffaf bir biçimde görünmesi sağlanacaktır.

3.8 Değişiklik Yönetimi Planı

Sistem gereksinimlerinde bir değişiklik (örneğin yeni bir lockfile tipi ekleme) önerildiğinde, bu öneri GitHub Issue olarak açılır. "Requirements Lead" (Ömer) değişikliğin kapsamını inceler. Değişiklik, ancak "Scrum Master" (Kaan) tarafından projenin 8 haftalık takvimine risk teşkil etmediği onaylandıktan sonra mevcut geliştirme döngüsüne entegre edilir.

3.9 Bütçe Planı

Projede parasal bir harcama (donanım/bulut sunucu maliyeti) bulunmamaktadır. Toplam "Bütçe", ekip üyelerinin haftalık ~15 saatlik zaman yatırımından oluşmaktadır. Efor, analizden çok geliştirme kodlamasına ve test süreçlerine ayrılmıştır.

3.10 Efor Tahminleri

Tahmin Yöntemi: Expert Judgment (Uzman Görüşü) ve Parametrik Modelleme kullanılarak haftalık kullanılabilir saatler modüllere paylaştırılmıştır.

- **Gereksinimler ve Planlama (Phase 1):** 60 saat.
- **Core Altyapı ve Tasarım (Phase 2 Başlangıcı):** 100 saat.
- **Algoritma ve Modül Geliştirme (Phase 2 & 3):** Toplam 260 saat (Parser, Vuln, License, Typosquat, Policy).
- **Test & QA Süreçleri (Phase 4):** 140 saat (Unit test, WireMock network kısıtlamaları testleri).
- **Kapanış & Dokümantasyon (Phase 5):** 40 saat.
- **Toplam Proje Eforu:** 600 saat (5 kişi x ~15 saat/hafta x 8 hafta).

3.11 Görev Atamaları

Görev atamaları, mimari modüllere (Component Ownership) göre yapılmış olup, her öğrencinin beceri (skill) hedefleriyle eşleştirilerek adil bir dağılım sağlanmıştır.

Modül / İş Paketi (Task)	**İlgili FR**	**Sorumlu**	**Neden (Rationale) Assignment-1.pdf**
Dependency graph & parser (yztr-parser)	FR-1, FR-2	Nuh Yusuf Sabırer	Architect rolü gereği temel girdi/veri yapılarını inşa etmeye uygundur.

Vulnerability Engine (yztr-vuln) & HTTP Layer	FR-3	Kaan Zor	Zafiyet veri tabanı iletişimi ve çevrimdışı (H2) sistem tasarımı konularında deneyim hedeflendiğinden.
License Engine (yztr-license)	FR-4	Ömer Ali Sarıcalar	Requirements Lead olarak SPDX uyumluluk senaryolarını kodlamaya (business logic) en hakim üyedir.
Typosquatting Detector (yztr-typosquat)	FR-5	Yusuf Emir Coşar	QA algoritmaları, levenshtein mesafesi optimizasyonları ve false-positive yönetimi QA Leader becerileri ile örtüşmektedir.
CLI, Policy Engine, GitHub Action	FR-6, 7, 8	Ramazan Emir Keleş	DevOps rolü gereği GitHub entegrasyonu, Markdown PR yorumları senkronizasyonu ve YAML parse işlemlerini üstlenmiştir.

Her üyenin katkısı, GitHub üzerindeki commit geçmişi ve açık/kapalı Issue'lar üzerinden bireysel düzeyde (Clarity of Contribution) net olarak izlenebilecektir.

3.12 Dokümana Özel Görev Matrisi (Project Plan Document)

Görev	**Sorumlu**	**Neden (Rationale) Assignment-1.pdf**
Organizasyon, Roller, Görev Matrisinin Hazırlanması	Kaan Zor	Scrum Master rolüyle proje takvimini, kaynak planını ve iletişim/risk süreçlerini yönettiği için.
Geliştirme Aşamalarının ve	Nuh Yusuf Sabırer	Geliştirme sürecinin mimari bağımlılıklarını (Gantt/Timeline)

Modüllerin Planlanması		teknik mantığa göre kurabilecek üye olduğu için.
Bütçe ve Efor (Person-hours) Tahminlerinin Hesaplanması	Ramazan Emir Keleş	Dağıtım (Release) süreçleri ve operasyon eforunu DevOps penceresinden net görebildiği için.